

Points forts de sécurité observés dans STAGIA-RDC

Une lecture structurée des mécanismes de protection présents dans le code applicatif.

Analyse statique du code - 24 septembre 2026

Périmètre : ce document présente des contrôles observés dans le dépôt. Il ne constitue pas un test d'intrusion, ni une certification de la configuration de production, des accès serveurs ou du réseau.

L'application met en œuvre une défense en profondeur : contrôle d'accès par rôles et permissions contextualisées, protection CSRF, cloisonnement des données, validation des entrées, transactions, journalisation et règles de cycle de vie métier.

01

Authentification, sessions et habilitations

- Les actions sensibles sont précédées de gardes de rôle, de permission et, selon le contexte, de périmètre établissement ou unité.
- Les autorisations sont centralisées par les mécanismes `requireRole`, `requirePermission` et `contextPermission` plutôt que répétées de manière dispersée.
- Le contrôle contextuel limite un acteur habilité à son propre périmètre fonctionnel.

02

Protection contre les requêtes intersites (CSRF)

- Plusieurs opérations d'écriture vérifient un jeton CSRF stocké en session avec une comparaison résistante au timing (`hash_equals`).
- Ce contrôle est observé notamment dans les parcours de présences, dispositifs, rotations, résultats, plans de formation et conventions.

03

Isolation des données et identité serveur

- Les requêtes métiers intègrent le périmètre de l'établissement hôte ou propriétaire afin d'éviter les accès entre structures.
- L'identité de l'étudiant est résolue depuis la session dans les parcours concernés, au lieu de faire confiance à un identifiant transmis par le navigateur.
- Les consultations de documents et de dossiers vérifient l'association avec l'acteur, l'établissement ou le contexte de stage.

04

Validation des entrées et des documents

- Les valeurs attendues sont fréquemment limitées par listes blanches : statuts, formats, tailles, dates et capacités.
- Les téléversements PDF contrôlent l'extension, la signature de fichier %PDF- et une limite de taille avant enregistrement.
- Les données sont également recoupées avec les enregistrements métier existants avant les décisions importantes.

05

Atomicité et concurrence

- Les parcours critiques utilisent des transactions SQL avec validation complète, commit ou rollback en cas d'erreur.
- Des verrous FOR UPDATE protègent certaines transitions concurrentes : présences, placements, résultats et métadonnées documentaires.
- Cette approche réduit les doubles réservations, les changements simultanés incohérents et les écritures partielles.

06

Traçabilité des décisions

- Des historiques conservent les revues de présence, les évaluations, les placements, les participations et les transmissions de résultats.
- Les traces associent les événements aux dates et aux utilisateurs, ce qui soutient l'investigation et la redevabilité.

07 Intégration des dispositifs de présence

- Les clés d'accès des dispositifs sont stockées sous forme de hachage SHA-256 ; la clé en clair n'est affichée qu'à la création ou à la rotation.
- L'ingestion vérifie l'équipement, déduplique les événements et refuse les événements datés dans le futur.

08 Protection documentaire et cycle de vie

- Les fichiers de conventions sont reliés au dossier étudiant et placés dans un espace protégé par une règle Apache interdisant l'accès direct.
- Les réponses de consultation appliquent aussi des en-têtes utiles, notamment no-cache pour les conventions et nosniff.
- Les transitions de campagne, convention, réservation, rotation et résultat sont limitées à des états métier autorisés.

- Les accès ne reposent pas sur un unique contrôle : rôle, permission et périmètre métier se complètent.
- Les opérations critiques sont conçues pour rester cohérentes en cas d'erreur ou de concurrence grâce aux transactions et verrous.
- Les décisions et transmissions sensibles sont historisées pour faciliter le suivi et les investigations.
- La prochaine étape d'audit consiste à confirmer ces protections en environnement réel : HTTPS, paramètres PHP et base de données, droits de fichiers, journaux et tests dynamiques.

Familles de fichiers examinées

- includes/auth.php, includes/permissions.php et includes/rbac-session.php
- actions/stages/host-attendance-save.php et attendance-device-ingest.php
- actions/stages/convention-upload.php, d4-placement-confirm.php et university-application-decision.php
- actions/stages/host-results-send.php et les actions de campagnes, rotations et évaluations